URGENT: Microsoft 365 Account Suspension Notice

Simulated Threat Scenario: Phishing / Credential Harvesting Incident

Incident Overview & Intercepted Communication

The following communication was intercepted by enterprise perimeter mail filters targeting multiple finance team members. It exhibits classic high-confidence indicators of malicious credential harvesting and typo-squatted phishing redirection.

Intercepted Email Headers & Payload

From: IT Helpdesk Support To: payroll-team@enterprise.example.org Date: October 13, 2026 08:14:22 UTC Subject: FINAL WARNING: Immediate verification required for your corporate account

Message Body Content

Dear Valued Employee, Our automated identity protection monitoring has detected multiple irregular sign-in attempts from unrecognized location IP address 198.51.100.45 attempting to access your corporate workstation and email mailbox. Due to critical security policy violations, your single sign-on access will be PERMANENTLY DISABLED within 2 hours unless you authenticate your identity immediately. Please click the secure validation portal link below to confirm your password and multi-factor authentication code: hxxp://login-verify-account[.]example[.]com/auth/login.php?user=payroll-team Failure to complete verification prior to the deadline will result in total revocation of email access and file shares. Sincerely, Corporate Systems Administration Desk

Technical Indicator Breakdown

Automated inspection identified multiple distinct Indicators of Compromise (IoCs) and deceptive manipulation heuristics:

Indicator	Type	Assessed Threat Level	Context Offset
login-verify-account[.]example[.]com	Domain	Critical Malicious	URL Hostname
198.51.100.45	IPv4	Suspicious Remote Host	Header Claim
admin-support@mail-verify365[.]example[.]com	Email	Phishing Sender	Return Path
hxxp://login-verify-account[.]example[.]com/auth/login.php	URL	Credential Harvesting	Payload Link

Identified MITRE ATT&CK; Techniques

• **T1566.002 (Phishing: Spearphishing Link)**: Utilizes deceptive link to harvest enterprise credentials.

• **T1078 (Valid Accounts)**: Intended adversary objective to compromise corporate SSO accounts.

Recommended Incident Response Containment Actions

Security Operations Center (SOC) containment playbook for credential phishing incidents:

1. **Perimeter DNS Sinkhole**: Immediately blackhole domain `login-verify-account[.]example[.]com` on internal resolvers.

2. **Email Purge**: Issue global Microsoft 365 Exchange purge for message ID to remove all delivered instances.

3. **Token Revocation**: Force session logout and password reset for any employee who clicked the landing link.

4. **Endpoint Telemetry Query**: Check EDR logs for outbound web socket connections to `198.51.100.45`.

Assessed Triage Severity: HIGH (8.8 / 10.0)